

CISSP Printable Practice Exam 26 - Domain 2 - Asset Security

Practice Exam 04 - Domain 2

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP4-025)

Scenario: An international relief organization maintains a small directory containing the current locations of temporary shelters for people escaping violence. The directory has little commercial value, but unauthorized disclosure could expose residents to physical harm.

Which factor should have the GREATEST influence on the directory's classification?

- A. The small number of records in the directory
- B. The potential harm to individuals if the locations are disclosed
- C. The limited cost of recreating the directory
- D. The absence of proprietary financial information

Question 2 (CISSP4-026)

Scenario: A payroll service provider processes employee data under a client's documented instructions. The provider asks to reuse the data to develop a separate workforce-benchmarking service that was not included in the original purpose.

What should occur before the proposed use begins?

- A. The provider may proceed because it already possesses the data lawfully.
- B. The data custodian may approve the new purpose because it operates the storage platform.
- C. The controller must evaluate and explicitly authorize the new purpose and any resulting requirements.
- D. The provider may proceed after removing the client's classification labels.

Question 3 (CISSP4-027)

Scenario: A museum creates removable backup media containing public exhibit descriptions, internal operating procedures, and restricted donor records. The backup process does not separate the datasets onto different media.

How should each backup medium be handled?

- A. According to the classification that represents the largest number of files
- B. As internal because the public and restricted content balance each other
- C. According to whichever dataset is restored most frequently
- D. At the most restrictive classification represented on the medium

Question 4 (CISSP4-028)

Scenario: A film-production company must send restricted pre-release footage on encrypted media to a remote editing location. The recipient is authorized, but the standard courier service does not record custody transfers or verify the receiving individual.

Which approach BEST meets the handling requirement?

- A. Use approved packaging and transport with documented custody, tracking, and verified receipt by an authorized person.
- B. Use the standard courier because encryption eliminates the need for physical accountability.
- C. Send two identical copies through different couriers to improve the chance of delivery.

D. Remove the restricted marking so the package attracts less attention during transit.

Question 5 (CISSP4-029)

Scenario: A renewable-energy company is introducing a new classification level for commercially sensitive site-acquisition records. The business executive designated as data owner and the infrastructure group acting as custodian must divide the work correctly.

Which assignment of responsibilities is MOST appropriate?

- A. The custodian determines business sensitivity, and the owner operates the storage controls.
- B. The owner approves classification and authorized use, and the custodian implements the required controls.
- C. The owner configures every control, and the custodian approves new business purposes.
- D. The custodian approves classification and use whenever the infrastructure can support them.

Question 6 (CISSP4-030)

Scenario: A real-estate brokerage permits agents to use personal tablets for client documents. Devices currently connect after only a password check, and the company has no inventory record, managed workspace, or process for removing business data when an agent leaves.

What should be required BEFORE continued access is allowed?

- A. A signed statement that makes the agent solely responsible for any disclosure
- B. Annual confirmation that the tablet still belongs to the same agent
- C. Enrollment in an approved process enforcing minimum controls, business-data separation, inventory, and removal at exit
- D. A larger personal storage allowance so client documents do not need to be deleted

Question 7 (CISSP4-031)

Scenario: A publishing company plans to adopt an online workflow service. The business sponsor has selected the service, but no one has documented the service owner, permitted information classifications, retention behavior, support responsibility, or export and deletion process at termination.

What is the BEST next step?

- A. Complete the provisioning review and record lifecycle requirements before placing organizational data in the service.
- B. Begin with restricted data so the most demanding use case is tested immediately.
- C. Let each department decide independently which records the service may retain.
- D. Treat the service as a purchasing expense rather than an asset because the infrastructure is external.

Question 8 (CISSP4-032)

Scenario: A hospital maintains loaner laptops for visiting clinicians. Devices are taken from an unlocked cabinet, users are not recorded, and returned laptops may still contain local files and customized settings from the previous borrower.

Which TWO controls should be implemented? Select 2 of the 5 options below.

- A. Record each checkout and return against an identified user and asset.
- B. Allow borrowers to keep devices until another clinician specifically requests one.

- C. Restore and verify the approved baseline, including removal of prior-user data, before reassignment.
- D. Use a shared local account so every visiting clinician has the same experience.
- E. Remove inventory labels to discourage users from relying on a particular laptop.

Question 9 (CISSP4-033)

Scenario: A brokerage automatically deletes all collaboration messages after thirty days. Employees increasingly use the platform to approve transactions and document customer instructions that must be retained longer, while casual coordination messages have no continuing value.

Which approach BEST addresses the retention problem?

- A. Retain every collaboration message indefinitely because some messages are records.
- B. Keep the thirty-day rule because retention should be based on the communication platform.
- C. Require employees to copy every message into email before it can become a record.
- D. Classify messages by business content and apply the appropriate record schedule regardless of channel.

Question 10 (CISSP4-034)

Scenario: After a merger, a manufacturing group finds duplicate supplier records in two repositories. The repositories use different retention metadata, and one contains records associated with an active investigation. Management wants to delete one repository immediately to reduce cost.

What should the records manager recommend?

- A. Delete the smaller repository because it is less likely to contain the authoritative copy.
- B. Reconcile content, ownership, metadata, and holds before designating authoritative copies and disposing of validated duplicates.
- C. Keep both repositories permanently because duplicate records cannot be safely consolidated.
- D. Export only the newest files and delete all older copies regardless of their scheduled retention.

Question 11 (CISSP4-035)

Scenario: A design company discovers that employees upload project files to numerous cloud storage services. Security needs visibility into which services are used and a way to apply access and data-handling policy consistently across cloud activity.

Which technology BEST addresses this requirement?

- A. Digital rights management limited to documents already selected for protection
- B. A records archive configured only for long-term preservation
- C. A cloud access security broker providing discovery, visibility, and policy enforcement
- D. A hardware asset inventory for company-issued endpoints

Question 12 (CISSP4-036)

Scenario: An investment firm distributes confidential research reports to approved external advisers. The firm needs to restrict forwarding and printing and to revoke access when an adviser's engagement ends, even after the report has been delivered.

Which control is MOST appropriate?

- A. Digital rights management that applies persistent usage restrictions and revocation to the reports
- B. A longer archive period for all copies sent to external advisers
- C. A cloud inventory that lists services but does not control delivered documents
- D. A data classification label without an enforcement mechanism

Question 13 (CISSP4-037)

Scenario: A government contractor is returning leased multifunction printers. The devices scanned restricted documents and contain internal storage, but the facilities team treats them as ordinary office furniture and plans to release them directly to the lessor.

What should the security manager require before release?

- A. Delete stored address-book entries because document images expire automatically.
- B. Obtain a confidentiality promise from the delivery driver.
- C. Remove the asset tags because ownership is returning to the lessor.
- D. Identify the embedded media and perform or verify approved sanitization appropriate to the data and disposition.

Question 14 (CISSP4-038)

Scenario: Engineers troubleshoot a production billing service by capturing memory dumps that may contain customer data in use. The dumps are copied to a broad team workspace and remain there after incidents close.

Which TWO controls most directly reduce this exposure? Select 2 of the 5 options below.

- A. Retain every dump indefinitely in case a similar defect appears later.
- B. Restrict diagnostic captures to authorized personnel and approved protected locations.
- C. Treat the dumps as nonsensitive because they were created for troubleshooting.
- D. Permit engineers to move dumps to personal storage when the shared workspace is full.
- E. Apply a defined retention period and securely dispose of dumps when the diagnostic need ends.

Question 15 (CISSP4-039)

Scenario: A travel company approves destruction of an expired customer dataset stored in a versioned cloud repository. An administrator deletes the current objects, but earlier versions and replicated copies remain recoverable under the service's standard settings.

What is the BEST completion criterion for the destruction process?

- A. The current objects no longer appear in the ordinary user interface.
- B. The administrator records that a delete command was issued successfully.
- C. All in-scope versions and replicas are removed or expire under an approved, verified destruction process.
- D. The data owner can no longer open the original object links.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP4-025) - Correct: B

Classification should reflect the potential impact of compromise, including harm to people. Low volume, low recreation cost, and lack of commercial value do not reduce the severe confidentiality consequence created by exposing shelter locations. The sensitivity of an asset is not determined only by its size or monetary value.

Question 2 (CISSP4-026) - Correct: C

A processor acts on the controller's documented instructions and cannot independently create a materially different processing purpose. The controller must assess and authorize the new use, including necessary contractual and protection requirements. Possession, storage responsibility, or removal of labels does not establish authority for secondary use.

Question 3 (CISSP4-027) - Correct: D

When information of different classifications is combined and cannot be separately controlled, the medium must receive protection sufficient for the most restrictive content. File volume and restoration frequency do not reduce the sensitivity of the donor records, and lower-classified data cannot offset higher-classified information.

Question 4 (CISSP4-028) - Correct: A

Classified physical assets require accountable transport in addition to technical safeguards. Approved packaging, documented custody transfers, tracking, and verified receipt preserve control throughout delivery. Encryption does not eliminate loss or custody requirements, duplicate shipments increase exposure, and removing a marking does not change the asset's classification.

Question 5 (CISSP4-029) - Correct: B

The data owner is accountable for classification and authorized use, while the custodian implements and operates the required technical and procedural safeguards. A custodian does not independently determine business sensitivity or authorize new purposes, and the owner provides requirements rather than personally administering every control.

Question 6 (CISSP4-030) - Correct: C

Personally owned devices that handle organizational data still require controlled provisioning. Enrollment should establish an accountable inventory record, required safeguards, separation of business data, and an enforceable removal process. Liability statements and ownership checks do not implement protection, while additional storage encourages unnecessary retention.

Question 7 (CISSP4-031) - Correct: A

A hosted service must be provisioned as an organizational asset with accountable ownership and defined rules for classification, retention, support, export, and termination. Starting with restricted data creates exposure before requirements are established. Department-level improvisation is inconsistent, and external hosting does not remove lifecycle accountability.

Question 8 (CISSP4-032) - Correct: A, C

Checkout records establish custody and accountability, while restoring a verified baseline prevents one borrower's data and changes from carrying into the next assignment. Open-ended possession weakens inventory control, shared accounts reduce traceability, and removing labels makes asset reconciliation more difficult.

Question 9 (CISSP4-033) - Correct: D

Record status and retention follow the business content and purpose, not the technology used to communicate. Content-based capture preserves transaction records while allowing transitory messages to expire. Indefinite retention creates unnecessary exposure, a channel-wide deletion period loses required records, and copying messages to email merely changes location.

Question 10 (CISSP4-034) - Correct: B

Consolidation should identify authoritative records and preserve required metadata, retention periods, and investigation holds before any copy is destroyed. Repository size or file age does not establish authority. Permanent duplication adds cost and exposure, while immediate deletion could remove required or held records.

Question 11 (CISSP4-035) - Correct: C

A cloud access security broker is designed to provide visibility into cloud-service use and enforce organizational access and data policies across cloud interactions. Digital rights management protects designated content but does not discover the broader service landscape. Archiving and endpoint inventory address different lifecycle and asset-management needs.

Question 12 (CISSP4-036) - Correct: A

Digital rights management can attach persistent controls to designated documents, including restrictions on use and the ability to revoke access after distribution. Retention does not constrain recipient actions, service inventory does not govern the delivered report, and a label communicates requirements but does not enforce them by itself.

Question 13 (CISSP4-037) - Correct: D

Multifunction devices can retain document data on embedded storage and must be handled as data-bearing assets. Approved, verified sanitization should occur before the equipment leaves custody. Address-book deletion is incomplete, a driver's promise does not remove remanence, and asset-tag removal is administrative rather than protective.

Question 14 (CISSP4-038) - Correct: B, E

Memory dumps can contain sensitive data in use, so access and storage locations should be tightly controlled and copies removed when the approved diagnostic need ends. Their technical purpose does not lower sensitivity. Indefinite or personal retention expands exposure and defeats accountable lifecycle management.

Question 15 (CISSP4-039) - Correct: C

Destruction is complete only when all copies within the approved scope, including recoverable versions and replicas, are addressed and the result is verified. Hiding current objects, logging a command, or breaking links may leave the underlying information recoverable and therefore still retained.